UFCFRB-15-3

Security Management in Practice

Academic Year 2025–2026

University of the West of England (UWE), Bristol

GROUP REPORT

Information Security Management System (ISMS) Proposal

Case Study: RAILcom

Module Code:	UFCFRB-15-3
Module Leader:	Kaushal Rimal
Academic Year:	2025–2026
Submission Date:	30 April 2026
Group Number:	5
Group Leader:	Aashna Sharma Badhi
Team Members UWE IDs:	Dipesh Sah = 23045189 Anurodh Rokaya = 23045171 Rabibhusan Yadav = 23000973 Aashna Sharma Badhi = 23000964 Sabin Roka = 23000975 Suraag Baniya = 23000982

1. Introduction & Scope

Railcom is a transport operator based in UK. This company is looking to undergo a massive digital transformation with its “Railcom 2.0” initiative but has experienced significant cybersecurity breaches affecting payroll and customer-facing systems. The incidents highlight how a bad cybersecurity posture can disrupt a company’s operations and result in financial loss and reputational damage.

This report presents a structured proposal for implementing Information Security Management System (ISMS) at Railcom. The ISMS is aligned with ISO 27001:2022 and will provide risk-based approach to managing information security, ensuring applicable compliance, and most importantly restore customer trust.

2. Organisational Overview: RAILcom

2.1 Business Objective

Railcom is a railway company which operates in a competitive rail transport market. The company is looking to undergo a significant digital transformation with “Railcom 2.0” initiative. The initiative is to expand the company’s digital services to reach out easily with its customers.

The main objectives of this transformation are as follows:

- Efficient rail services: Railcom’s main function is to deliver reliable, safe passenger rail transport. This includes operating trains, maintaining infrastructure, managing schedules while ensuring customer satisfaction.

- Digital Modernization - This involves transitioning from legacy rail operations into one comprehensive online platform (i.e. ticketing, scheduling and customer relationship management).

- ComCard Launch: The company is looking to introduce prepaid smart card system called “ComCard” for multi-transit payment purposes. This is expected to be sold at ticket counters initially but afterwards through online platforms.

- Customer-Centric Growth: Railcom is looking to shift sales from physical counters to digital platforms to compete effectively against its competitors in a declining rail market while enhancing speed and customer experience.

Railcom’s CEO plans to roll out Railcom 2.0 within 6-month timeline. This short time period created significant pressure on security implementation and system integration.

2.2 Key Assets at Railcom

Railcom's critical assets that require protection are given below with their category.

Asset Category	Specific Assets
Information Assets	• Customer PII (Personally Identifiable Information): Names, contact information, payment details, travel history etc • Employee payroll records: Bank account details, salary information, personal data etc. • Financial Data: Comcard balances, payment transactions, ticket sales.
Technical Assets	• Legacy infrastructure: 1980s mainframe systems, middleware softwares. • Digital Platforms: ComCard web interface, ticketing system, CRM databases • Network Infrastructure: Internal networks, branch connections, firewalls.
Intangible Assets	• RAILcom brand reputation and customer trust.
External/ Supporting Assets	• Domain Registration Services: Used for railcoms registered digital domains.(eg railcom.com) • Payment Processing Providers: Thirdparty payment gateways which are used online transactions. • Internet Service Providers:Connectivity providers for organization offices.

2.3 Organizational Roles & Security Responsibilities

Railcom's organizational structure is composed of executive leadership, operational management, and other workforces across divisions. Each role uniquely contributes to the company's strategic direction, operational efficiency, and security posture. The following outlines responsibilities of different people in the organization:

- **James Rith – Chief Executive Officer (CEO)**

James provides overall leadership and vision for Railcom. He is responsible for leading the “Railcom 2.0” campaign and ensuring alignment between corporate objectives and long-term growth.

- **Hank – Chief Financial Officer (CFO)**
  Hank oversees Railcom’s financial operations which includes budgeting, allocating resources, and fiscal planning. His role ensures that investment in key areas like technology, infrastructure, and security are financially sustainable and strategically aligned.

- **Alice – Chief Information Officer (CIO)**
  Alice plays a pivotal role in managing Railcom’s IT infrastructure. She is responsible for supervising technological infrastructure projects, strengthening cybersecurity, and driving innovation to enhance operational efficiency.

- **Lev – IT (Information Technology) Director**
  Manages technology resources and employees to ensure that IT operations run smoothly. His focus is on ensuring smooth day-to-day IT operations, maintaining systems, and supporting the CIO in implementing security.

- **Kira**
  Kira is an employee at Railcom who has cross-divisional access. She alongside many employees have unchecked/unauthorized privileges which is consequences of Railcom’s weak cybersecurity culture.

2.4 Security Challenges at Railcom

Railcom faces various security challenges that stem from its reliance on digital modernization, cross-divisional access, and external technology partners. These challenges highlights the importance of integrating cybersecurity into its organizational strategy. The following are some of the challenges that Railcom faces:

1. **Insider Threats**
   As Railcom modernizes its operation and expands digital platforms, the company faces significant security challenges. The most significant one being employees with unauthorized privileges. Employees at Railcom have cross-divisional access and this privilege can be misused to compromise sensitive data or disrupt operations. Incidents like Snowden leaks demonstrate how insider misuse can undermine secure systems and organizations.

2. **Legacy Systems & Digital Transition**
   Challenge arises from Railcom's heavy reliance on legacy infrastructure while transitioning to digital ticketing and scheduling platforms. These legacy systems often lack modern security updates, and they are a vulnerability ready to be exploited during integration. The WannaCry ransomware outbreak in 2017 is a prime example of how outdated systems can be weaponized to disrupt critical services like transport networks.

3. **Third-Party Dependencies**
   Railcom also depends on external technology partners for various services. These services include domain registration, payment systems, internet. These external services introduce risks beyond Railcom's direct control. The Target breach of 2013 also originated from a third-party vendor. This shows evidence of why vulnerabilities in external partners can cascade into the core business.

4. **Customer Data & Payment Systems**
   Customer data protection is another major concern for Railcom. As Railcom is looking to introduce Comcard which is a prepaid smart card system and online ticketing, these platforms make Railcom a target for cybercriminals seeking financial data. The British Airways breach in 2018 is an perfect example of this, where attackers compromised payment systems. It highlighted the potential consequences of inadequate web application security.

5. **Operational Disruption & Critical Infrastructure**

   Railcom must contend with the broader risk of operational disruption. As a provider of critical infrastructure, any cyber incident that affects scheduling, ticketing, or train operations could halt services and compromise passenger safety. The Colonial Pipeline ransomware attack in 2021 demonstrated how cyberattacks can paralyze essential services, underscoring the need for resilience in transport systems.

3. ISMS Justification & Framework Selection

3.1 Why an ISMS is Critical for RAILcom

An information security management system (ISMS) is a set of policies and procedures which helps in systematically managing an organization's sensitive information. It is a framework that helps companies identify their security risks and implement appropriate measures with the goal of minimizing risks and ensuring business continuity. It protects companies against cyber-attacks. It also helps them with legal compliance, and structure risk assessment, and most importantly strengthens customer confidence.

An ISMS is critical for Railcom because it protects the company's customer data, digital platforms, and critical operations against cyber threats. The company's reliance on old legacy systems, third party services, and online ticketing system makes it vulnerable to various attacks. These attacks

can disrupt services, compromise passenger safety, and damage trust. By having a structured system like ISMS in place, Railcom can identify risks early, apply safeguards and ensures business continuity.

3.2 ISMS Framework Selection: ISO 27001

The most appropriate framework for Railcom is ISO/IEC 27001. This standard is internationally recognized and provides a structured, risk-based approach to managing information security across people, processes, and technology. These are the exact areas where Railcom has demonstrated weaknesses. Unlike NIST CSF, which is more flexible and guidance-oriented, ISO 27001 offers a certifiable framework. Railcom can use this to demonstrate compliance and build customer trust. Given Railcom's exposure to insider threats, legacy systems, and third-party dependencies, ISO 27001's emphasis on continuous risk assessment, asset classification, and control implementation makes it the most suitable choice.

Justification for selection ISO 27001 are as follows:

- **Comprehensive Coverage:** ISO 27001 addresses all three aspects of Railcom's security challenges: people, processes, and technology. This ensures vulnerabilities are managed holistically rather than in isolation.

- **International Recognition:** A globally recognized standard that enhances credibility with stakeholders and customers. Its reputation reassures partners and investors of Railcom's commitment to security.

- **Regulatory Alignment**: Supports compliance with GDPR and other data protection regulations relevant to Railcom's operations. This reduces the risk of fines and reputational damage from non-compliance.

- **Continuous Improvement:** Built-in PDCA (Plan-Do-Check-Act) cycle ensures ongoing security enhancement. Railcom can adapt quickly to evolving threats and maintain resilience.

- **Risk-Based Approach:** Focuses on identifying and treating risks specific to Railcom's context and operations. This prioritization ensures resources are directed where they matter most.

- **Certifiable Framework:** Provides Railcom with an auditable certification that demonstrates commitment to security and builds customer trust. Certification also strengthens Railcom's competitive position in the transport sector.

- **Scalability**: Flexible enough to adapt to Railcom's growth, digital modernization, and new initiatives like ComCard. It can expand seamlessly as Railcom introduces new services or technologies.

- **Supplier Risk Management:** Explicit controls for managing third-party dependencies, a key vulnerability in Railcom's ecosystem. This reduces exposure to cascading breaches from external vendors.

- **Incident Response Integration:** Formalized processes for detection, escalation, and recovery, reducing downtime during cyber incidents. Railcom gains a structured way to respond quickly and limit damage.

- **Business Continuity:** Ensures resilience of critical rail services, minimizing disruption to passengers and operations. Continuity planning safeguards both revenue and public safety.

- **Employee Awareness:** Emphasizes training and cultural change, addressing insider threats and weak security practices. This builds a stronger security culture across the organization.

- **Alignment with Industry Best Practices:** Harmonizes Railcom's security posture with transport sector standards and global benchmarks. It ensures Railcom remains competitive and trusted in a highly regulated industry.

4. Risk Assessment Methodology & Findings

4.1 Methodology: ISO/IEC 27005:2022

We have performed risk assessment according to the international standard for risk management in the area of information security, ISO/IEC 27005:2022. This is highly correlated with ISO 27001.

Risk is calculated by:

- **Risk Score = Likelihood (1-5) × Impact (1-5)** leading to a score ranging from **1 to 25**.
- Based on the risk score, the risk can be classified as **Low (1-6), Medium (7-12), High (13-**19), or **Critical (20-25).**

To handle risks, some of the treatment options from ISO 27001 Annex A can be applied: **Reduce**, **Transfer**, **Avoid**, or **Accept**.

4.2 Major Vulnerabilities and Threats Identified

Railcom faces multiple security vulnerabilities and threats across people, processes, and technology.

4.2.1 Vulnerabilities

Vulnerabilities at Railcom can be categorized in the following way:

Technology Vulnerabilities:

- Legacy 1980s systems with outdated security controls.
- Middleware connections without proper security validation.
- Lack of network segmentation between critical systems.
- No formal patch management or vulnerability assessment processes.
- Weak authentication mechanisms across digital platforms.

People-Related Vulnerabilities:

- Employees lack security awareness and training.
- Interns and staff retain outdated access privileges.
- File-sharing practices enabling malware spread.
- Lack of incident response training and awareness.

Process Gaps:

- No segregation of duties - IT personnel accessing multiple systems.
- No formal incident response plan or escalation procedures.
- Absence of risk management framework and assessment processes.
- No 2FA or multiple protection layers for employees when they log in
- No regular security audits or compliance monitoring.

.

4.2.2 Threats

There are numerous threats that Railcom can face because of the vulnerabilities mentioned above.

1. **Cyberattacks (Ransomware, Phishing, DDoS, Data Breaches)**
   Railcom's reliance on interconnected ticketing systems, online payment gateways, and operational scheduling platforms makes it a prime target for cybercriminals. Ransomware

can lock critical systems, phishing campaigns can compromise employee credentials, and DDoS attacks can overwhelm online services. A successful breach could expose sensitive passenger data, disrupt train scheduling, and paralyze customer-facing portals.

2. **Insider Threats (Malicious or Accidental)**
   Employees with privileged access across divisions pose a significant risk. Malicious insiders may intentionally sabotage systems or leak confidential data, while careless staff may inadvertently mishandle sensitive information. Given Railcom's complex organizational structure, insider misuse of access rights could bypass perimeter defenses and directly compromise critical assets.

3. **Third-Party & Supply Chain Risks**
   Railcom depends heavily on external vendors for payment processing, and domain management. Weaknesses in vendor systems or inadequate security practices can cascade into Railcom's environment. A breach in a partner's infrastructure could expose Railcom's customer data or disrupt essential services, highlighting the importance of vendor risk management.

4. **Compliance Failures (Regulatory & Standards)**
   Failure to adhere to ISO/IEC 27001, GDPR, or transport safety regulations can result in severe penalties. Inadequate documentation, poor monitoring, or gaps in audit readiness may lead to fines, lawsuits, and reputational damage. Compliance failures also undermine stakeholder confidence in Railcom's ability to safeguard passenger data and operational integrity.

5. **Operational Disruption (Critical Infrastructure Attacks)**
   Attacks targeting scheduling systems, signaling networks, or ticketing platforms can halt train services entirely. Such disruptions not only affect revenue but also compromise passenger safety. The Colonial Pipeline incident serves as a stark reminder of how cyberattacks on critical infrastructure can cripple national services and erode public trust.

4.3 Proposed Risk Register

The complete ISMS Risk Register, with a complete asset mapping is provided for reference in a spreadsheet as a concurrent document. The following describes the twelve major risks in summary form:

ID	Risk Description	Cat.	L	I	Score	Level	Residual
R-01	Keylogger / Malware via Phishing Email	People / Tech	4	5	**20**	**CRITICAL**	8 – MED
R-02	Malicious Insider – Credential Theft & Payroll Fraud	People / Proc	3	5	**15**	**HIGH**	6 – MED
R-03	Ransomware — Absent Network Segmentation	Tech / Proc	4	5	**20**	**CRITICAL**	8 – MED
R-04	Brand Spoofing & Fraudulent ComCard Site	Tech / Proc	4	4	**16**	**HIGH**	6 – MED
R-05	Weak Passwords / No MFA Enforcement	People / Proc	5	4	**20**	**CRITICAL**	5 – MED
R-06	No Separation of Duties — Unrestricted IT Access	Process	4	4	**16**	**HIGH**	5 – MED
R-07	Legacy Payroll System — Unpatched & Unmonitored	Tech	4	4	**16**	**HIGH**	6 – MED
R-08	No Incident Response Plan — Delayed Containment	Process	3	5	**15**	**HIGH**	5 – MED
R-09	Customer Payment Data Theft — No PCI DSS Controls	Tech / Proc	4	5	**20**	**CRITICAL**	7 – MED
R-10	Data Leakage via Universal Serial Bus (USB) / Unmanaged Bring Your Own Device (BYOD) Devices	People / Tech	4	3	**12**	**MEDIUM**	3 – LOW
R-11	Uncontrolled File Sharing — Malware Propagation	Tech / Proc	4	4	**16**	**HIGH**	5 – MED
R-12	No Employee Cybersecurity Training or Culture	People	5	4	**20**	**CRITICAL**	6 – MED

4.4 Business Impact Analysis

This breach impacted five of RAILcom's operational areas, resulting in cumulative damage to RAILcom's future viability.

1. **Service Downtime & Revenue Loss**
   System outages caused by ransomware or DDoS attacks can suspend ticket sales, delay train schedules, and halt operations. Every hour of downtime translates into lost revenue, dissatisfied customers, and cascading logistical challenges across the network.

2. **Reputation Damage & Loss of Trust**
   A breach involving customer data such as Railcom's ComCard smart card system—would erode public trust. Passengers may hesitate to use digital services, preferring competitors perceived as more secure. Reputation damage is often long-lasting, requiring significant investment in PR and customer reassurance.

3. **Regulatory Penalties & Legal Exposure**
   Compliance failures can trigger fines, lawsuits, and stricter oversight. Non-compliance with GDPR, for example, could result in multimillion-dollar penalties. Beyond financial costs, regulatory sanctions can delay modernization projects and force Railcom into reactive compliance measures rather than proactive security improvements.

4. **Safety Risks & Passenger Welfare**
   Operational disruptions directly affect passenger safety. A compromised scheduling or signaling system could lead to accidents, delays, or unsafe conditions. The risk extends beyond financial loss to human lives, making cybersecurity a matter of public safety as well as business continuity.

5. **Strategic Setbacks & Innovation Delays**
   Vendor breaches or insider misuse can derail digital transformation initiatives. Projects aimed at modernizing ticketing, introducing smart cards, or enhancing passenger experience may stall due to diverted resources and heightened risk management priorities. This slows Railcom's competitive edge in the transport sector.

5. Security Controls & Mitigation Strategies

Controls have been categorized into three dimensions of cybersecurity triangle using ISO 27001:2022 Annex A.

5.1 Technological Controls

Control	Implementation at RAILcom	ISO 27001:2022 Ref.	Risks Mitigated
Multi-Factor Authentication (MFA)	TOTP/push-based MFA for all divisions in Railcom and hardware tokens for finance/admin staff.	A.8.5 — Identity authentication	This will help in preventing unauthorized access even when credentials are compromised. (R-01, R-05, R-02).
Endpoint Detection & Response (EDR)	This will help with continuously monitoring devices. It also helps to prevent malwares and provides proper forensic log.	A.8.7 — Malware protection	Stops malware infection and helps in further investigations.It also reduces risks of systems being compromised. R-01, R-11, R-07
Network Micro-Segmentation / VLANs	Segregation of payroll, ComCard CDE, CRM, and corporate LAN into separate VLANs.	A.8.20 / A.8.22 — Network segmentation	Prevents lateral movement of attackers. R-03, R-09, R-02
DMARC / DKIM / SPF Enforcement	Email authentication protocols enforced are enforced and helps identifying spoofed emails.	A.8.23 — Web filtering	Helps mitigate phishing risk among others. R-04, R-01
Patch Management Policy	Helps railcom in implementing quarterly vulnerability scans, documenting patch schedule.	A.8.8 — Vulnerability management	Closes exploitable gaps and prevents ransomware leveraging outdated systems. R-07, R-03
Point-to-Point Encryption (P2PE)	Tokenization of ComCard, encryption of payroll/HR records, and TLS 1.3 for payment pages.	A.8.24 — Cryptography	This protects cardholder and personal data ultimately ensuring PCI DSS compliance. R-09, R-05

5.2 People Controls

- **Mandatory security awareness training (A.6.3)** – This is sort of annual gamified programme with monthly phishing simulations and immediate coaching feedback. Proofpoint (2023) reports up to 86% reduction in click rates. CEO must visibly champion the programme.

- **Clean desk policy & BYOD management (A.7.7, A.6.7)** - clean desk policy (ex. no post-it notes with passwords or live computer sessions left unattended).Mobile Device Management (MDM) (Microsoft Intune) for all personal devices that can access the corporate network.

- **Hiring & re-vetting policies (A.6.1)** – This involves background checks for all positions that access critical systems, annual re-vetting of finance and IT professionals. Kira's attack shows the price of no vetting.

- **Chief executive officers' security champion program** - CISO reports quarterly breach intelligence to the board; cybersecurity KPIs become a key component of senior managers' reviews; board tabletop exercises twice a year. This helps in holding higher executives accountable.

5.3 Process Controls

- **Separation of Duties and Role-Based Access Control (A.5.3, A.8.2)** – This will prevent privilege misuse and unauthorized access to sensitive systems.

- **Incident Response Plan - IRP (A.5.24, A.5.26) -** The IRP is developed according to NIST SP 800-61r2. This includes escalation matrix,ICO notification, breach communication, and evidence handling.

- **Joiner-Mover-Leaver (JML) Process (A.5.18)** - this process provides an automated system to remove access for a user within 24 hours after an employee leaves the company or is transferred to another division.

- **Data Protection Impact Assessment (DPIA)** – This process is conducted for new products (e.g., ComCard) and helps integrating GDPR Article 25 Privacy by Design.

6. Applicable Legal & Regulatory Compliance

6.1 UK General Data Protection Regulation (UK GDPR / EU GDPR)

The UK GDPR, which still exists today through the Data Protection Act 2018, is the principal personal data law that governs RAILcom's operation. The customer data breach seen at Railcom reveales violations of the following provisions:

- **Article 32, Implementation of apt security measures**: During the incident, Railcom lacked encryption, multi-factor authentication, and documented technical safeguards. The ICO can impose penalties up to £17.5 million or 4% of global turnover of the company. (ICO, 2023)

- **Article 33, Breach notification within 72 hours**: The ComCard phishing site was active for 30 days before the ICO was notified. There was no breach notification procedure in place.

- **Article 25, Privacy through default and privacy by design**: No Data Protection Impact Assessment (DPIA) was done prior to the ComCard platform. The client-side coding was outsourced without security standards.

ISMS Alignment:

- The Incident Response Plan (IRP) specifies 72-hour breach notification procedures.
- DPIAs are mandated for new products. (Article 25).
- ISO/IEC 27001 Annex A controls provide the “appropriate measures” required under Article 32.
- ISO 27001 certification is recognized by the ICO as evidence of compliance (ICO, 2021).

6.2 Payment Card Industry Data Security Standard (PCI DSS)

PCI DSS is an information security standard used to handle credit cards from major card brands. It was created to protect card holders’ data and has twelve requirements for compliance. This applies to ComCard system and online payment platforms at Railcom. Violations identified at Railcom regarding ComCard include:

- Requirement 1: Absence of network security controls.
- Requirement 3: No encryption or protection of the Cardholder Data Environment (CDE).
- Requirement 6: Lack of a secure development lifecycle for ComCard.

- Requirement 8: No MFA or strong authentication.
- Requirement 12: No written security policy.

ISMS Alignment:

- Network micro-segmentation separates and protects the CDE.
- Tokenization and TLS 1.3 encryption meet Requirement 3.
- MFA rollout satisfies Requirement 8.
- ISMS policy documentation fulfills Requirement 12.

6.3 NIS2 Directive — (EU 2022/2555)

The NIS2 Directive is a unified legal framework which helps to uphold cybersecurity in 18 critical sectors across the EU nations. As Railcom is a railway operator, it qualifies as an Essential Entity under Annex I of NIS2. The following are its key obligations:

- **Article 21 – Risk Management**
  This article requires continuous risk management, supply chain security, and business continuity planning. These are not fully implemented at Railcom

- **Article 23 – Incident Reporting**
  Data breaches must be reported within 24 hours and a full incident report is to be submitted within 72 hours to national authority. Railcom failed to do this.

- **Article 32 – Management Accountability**
  This article states that senior management like CEO, board members also must bear personal responsibility for compliance.

ISMS Alignment:

- ISO 27001 accreditation provides a recognized risk management methodology. This is under article 21.
- The IRP defines 24/72-hour reporting procedures.
- Supplier security screening addresses supply chain requirements.

6.4 HIPAA — Health Insurance Portability and Accountability Act

HIPAA is a US federal law and therefore not directly binding on RAILcom as a UK-registered company. That said, it is still relevant in a couple of ways:

- **Employee Health Data:** Firstly, RAILcom's HR systems administers employee health data that has been classified as 'special category data' under GDPR Article 9. Thus justifying the use of HIPAA's Security Rule as an international standard for increased safeguards (HHS, 2013).
- **Future U.S. Expansion:** If Railcom would enter into U.S. market, they would require full HIPPA compliance

ISMS Alignment:

- Special category data classification policy is applied.
- Role-Based Access Control (RBAC) is strengthened for HR records.
- DPIAs are required for all health data processing activities (Solove & Schwartz, 2021).

6.5 Consolidated Compliance Mapping

Regulation	Key Obligation	RAILcom's Failure	ISO 27001 Control	Compliance Evidence
UK GDPR Art.32	Appropriate technical and organisational measures	Absent of encryption, no MFA, no security policy	A.8.5, A.8.7, A.8.20, A.8.24	ISO 27001 certification; penetration testing reports; audit logs
UK GDPR Art.33	72-hr ICO breach notification	No notification process; 30-day undetected breach	A.5.24, A.5.26	IRP documentation; ICO notification logs
UK GDPR Art.25	Privacy by design; DPIA requirement	ComCard was not assessed by a DPIA; it was outsourced without security requirements	A.8.25, A.8.27	DPIA register; SDLC policy

Regulation	Key Obligation	RAILcom's Failure	ISO 27001 Control	Compliance Evidence
PCI DSS Req.1 & 3	CDE isolation; protect cardholder data	No segmentation; no encryption or tokenisation	A.8.20, A.8.22, A.8.24	Network diagrams; QSA audit; ASV scan
PCI DSS Req.8	Strong authentication for CDE access	Not a single user anywhere in the organisation was using MFA	A.8.5	MFA deployment logs; access reviews
NIS2 Art.21	Risk management framework for essential entities	No framework; no supply chain controls	Full ISO 27001:2022	ISO cert.; risk treatment plan; ORR registration
NIS2 Art.23	24-hr early warning; 72-hr full report	No reporting capability	A.5.24, A.5.26	IRP; SIEM alert logs; ORR notification records
HIPAA (benchmark)	Safeguards for health-related information	Health data within unprotected HR systems	A.5.12, A.5.33	DPIA; RBAC logs; data classification policy

7. ISMS Implementation Roadmap

7.1 Critical Implementation Challenges

Our research suggests that there are several barriers that stop organisations from implementing ISMS as intended (Disterer, 2013; Beckers, 2015). RAILcom exemplifies each:

- **Budget Constraints** – Advanced tools like EDR,SIEM,MFA tokens require significant investment. Patching legacy systems and vendor audits are adds ongoing costs continuously. As Railcom is not a very profit thriving company, its budget can be an challenge in implementing ISMS.

- **Executive complacency and organisational culture** - James's response to the threat landscape was further communicated to the remainder of the organisation that security wasn't a priority. This is cited by von Solms and van Niekerk (2013) as the hardest obstacle to ISMS implementation because no control can be sustained without executive support.

- **User acceptance and behaviour change** - Sticky-note passwords, open screen passwords, using your own device for work are all behaviours that defy compliance-training efforts (Bulgurcu et al., 2010). Proofpoint (2023) shows that regular monthly simulations (not annual training presentations) are needed to achieve behaviour change. Employees at Railcom may resist new policies (clean desk, MFA, phising simulations). Changing the culture around cybersecurity can also be an challenging factor while trying to implement ISMS.

- **Lack of established cyber governance** - no DPO, no CISO, no audit cycle, no JML. The severe non-compliance and lack of performance within RAILcom (less than 10% know about it) of the documented 'predict-prevent-detect-respond' policy shows Ahmad et al.'s (2014) proposition that documentation alone, without actions is a security threat.

7.2 Phased Implementation Roadmap

Phase	Actions	Priority Controls	Target
Phase 0 **IMMEDIATE**	• Designate board-level CISO • Designate Data Protection Officer (DPO) • Register with ORR as a NIS2 Essential Entity • Staff release on breach; IRP drafting begins • Keep all forensic investigations intact for the police	CISO/DPO appointment; ORR registration; evidence chain of custody	**0–30 days**
Phase 1 **CRITICAL**	• Include MFA in all user accounts • Put Incident Response Plan (IRP) into practice and do a tabletop test • Start network micro-segmentation to isolate payroll and CDE only • Set up mandatory phishing simulation programmed • Enforce password management policy; carry out RBAC reviews • JML process is started for access deprovisioning • A full asset inventory was completed and the scope of the Information Security Management System (ISMS) formally defined	MFA (R-05); IRP (R-08); segmentation (R-03, R-09); RBAC (R-06); JML (R-06)	**30–90 days**
Phase 2 **HIGH**	• All endpoints should have EDR; Implement DMARC/DKIM/SPF	EDR (R-01, R-11); DMARC (R-04); PCI	**3–6 months**

Phase	Actions	Priority Controls	Target
	• Run first bi-annual penetration tests and vulnerability scans • Do the PCI DSS gap analysis; start tokenisation and TLS 1.3 • Make a DPIA for the ComCard online platform before launching it • Get clean desk policy and BYOD MDM controls in operation • Formalize patch management policy and change management process • Establish the pre-employment and regular re-screening program. • Conduct the first internal audit cycle of ISMS	DSS (R-09); BYOD (R-10); vetting (R-02)	
Phase 3 **SUSTAIN**	• Gradual SaaS switch of older payroll system • Tabletop exercise at executive board level and security KPI review • Internal audit cycle 2; management review - PCI ASV scan yearly; QSA assessment pre-ComCard launch • ISO 27001 Stage 1 (documentation) audit by the certification body • UEBA for insider threat detection. • Security assessments of supplier chain	Legacy migration (R-07); UEBA (R-02); supply chain (R-04); ISO certification	**6–18 months**

8. Conclusion

The Railcom customer data breach is a result of failed governance across people,processes, and technology. The legacy systems lacked defenses, existing policies were not implemented, and a complacent culture from top leadership to bottom management are the exact reason why Railcom's customers data were compromised.

A risk-based ISMS plan, built on ISO/IEC 27001:2022 identifies the all the twelve risks. Each risk is classified by its severity.Regulatory exposures are very significant for Railcom with violations of UK GDPR, PCI DSS, and NIS2. The potential penalties can exceed over 17.5 million pounds under GDPR alone.

The supporting ISMS Register translates this framework into practice. It also maps assets, risks, controls, and compliance requirements. Together, these provide Railcom's senior management with the evidence that for a company like Railcom, an ISMS like ISO 27001 is not an luxury but a necessity for business to survive in market.

9. Table of Abbreviations and Acronyms

Table provides the full forms of all abbreviations used throughout this report, listed in alphabetical order:

Abbreviation / Acronyms	Full Form
ASV	Approved Scanning Vendor (PCI DSS)
BCP	Business Continuity Plan
BYOD	Bring Your Own Device
CDE	Cardholder Data Environment
CERT	Computer Emergency Response Team
CFO	Chief Financial Officer
CIO	Chief Information Officer
CISO	Chief Information Security Officer
CRM	Customer Relationship Management
CSF	Cybersecurity Framework (NIST)
DKIM	DomainKeys Identified Mail
DMARC	Domain-based Message Authentication, Reporting and Conformance
DPO	Data Protection Officer
DPIA	Data Protection Impact Assessment
DSS	Data Security Standard (PCI)
EDR	Endpoint Detection and Response
EU	European Union
GDPR	General Data Protection Regulation
HIPAA	Health Insurance Portability and Accountability Act
HR	Human Resources
IBM	International Business Machines Corporation
ICO	Information Commissioner's Office

Abbreviation / Acronyms	Full Form
IEC	International Electrotechnical Commission
IRP	Incident Response Plan
ISMS	Information Security Management System
ISO	International Organisation for Standardisation
IT	Information Technology
JML	Joiner-Mover-Leaver (access lifecycle process)
KPI	Key Performance Indicator
MDM	Mobile Device Management
MFA	Multi-Factor Authentication
NHS	National Health Service
NIS	Network and Information Systems
NIS2	Network and Information Systems Directive 2 — (EU) 2022/2555
NIST	National Institute of Standards and Technology
ORR	Office of Rail and Road
PCI	Payment Card Industry
PDCA	Plan-Do-Check-Act (continuous improvement cycle)
PII	Personally Identifiable Information
QSA	Qualified Security Assessor (PCI DSS)
RBAC	Role-Based Access Control
SaaS	Software as a Service
SDLC	Secure / Software Development Lifecycle
SIEM	Security Information and Event Management
SoD	Separation of Duties
SPF	Sender Policy Framework
SSC	Security Standards Council (PCI)
TLS	Transport Layer Security

Abbreviation / Acronyms	Full Form
TOTP	Time-based One-Time Password
UEBA	User and Entity Behaviour Analytics
UK	United Kingdom
US	United States
USB	Universal Serial Bus
Virtual Local Area Network (VLAN)	Virtual Local Area Network
XP	

References

1. Ahmad, A., Bosua, R. and Scheepers, R. (2014) 'Protecting organisational competitive advantage: A knowledge leakage perspective', *Computers & Security*, 42, pp. 27–39. doi:10.1016/j.cose.2014.01.001

2. Beckers, K. (2015) *Pattern and security requirements: Engineering-based establishment of security standards*. Cham: Springer.

3. Bulgurcu, B., Cavusoglu, H. and Benbasat, I. (2010) 'Information security policy compliance: An empirical study of rationality-based beliefs and information security awareness', *MIS Quarterly*, 34(3), pp. 523–548. doi:10.2307/25750690

4. CERT (2023) *Common sense guide to mitigating insider threats*. 7th edn. Carnegie Mellon University Software Engineering Institute. Available at: https://www.cert.org/insider-threat/ (Accessed: 12 April 2026).

5. Disterer, G. (2013) 'ISO/IEC 27000, 27001 and 27002 for information security management', *Journal of Information Security*, 4(2), pp. 92–100. doi:10.4236/jis.2013.42011

6. European Parliament (2022) *Directive (EU) 2022/2555 on measures for a high common level of cybersecurity across the Union (NIS2 Directive)*. *Official Journal of the European Union*. Available at: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A32022L2555 (Accessed: 10 April 2026).

7. HHS (2013) *HIPAA security rule*. US Department of Health and Human Services. Available at: https://www.hhs.gov/hipaa/for-professionals/security/index.html (Accessed: 10 April 2026).

8. IBM Security (2023) *Cost of a data breach report 2023*. Armonk: IBM Corporation. Available at: https://www.ibm.com/reports/data-breach (Accessed: 12 April 2026).

9. ICO (2021) *Guide to the UK GDPR: Security*. Information Commissioner's Office. Available at: https://ico.org.uk/for-organisations/guide-to-data-protection/ (Accessed: 10 April 2026).

10. ICO (2023) *Fines and enforcement*. Information Commissioner's Office. Available at: https://ico.org.uk/action-weve-taken/enforcement/ (Accessed: 12 April 2026).

11. ISO/IEC (2022) *ISO/IEC 27001:2022, Information security, cybersecurity and privacy protection, Information security management systems, Requirements*. Geneva: International Organisation for Standardisation.

12. ISO/IEC (2022) *ISO/IEC 27005:2022, Information security, cybersecurity and privacy protection, Guidance on managing information security risks*. Geneva: International Organisation for Standardisation.

13. NAO (2018) *Investigation: WannaCry cyber-attack and the NHS*. National Audit Office. Available at: https://www.nao.org.uk/report/investigation-wannacry-cyber-attack-and-the-nhs/ (Accessed: 12 April 2026).

14. NCSC (2021) *Multi-factor authentication for online services*. National Cyber Security Centre. Available at: https://www.ncsc.gov.uk/guidance/multi-factor-authentication-online-services (Accessed: 10 April 2026).

15. NCSC (2023) *Cyber governance for essential entities: NIS2 implementation guidance*. National Cyber Security Centre. Available at: https://www.ncsc.gov.uk/guidance/nis2 (Accessed: 10 April 2026).

16. ORR (2022) *Network and information systems (NIS) regulations: Rail sector guidance*. Office of Rail and Road. Available at: https://www.orr.gov.uk/monitoring-and-enforcement/network-information-systems (Accessed: 12 April 2026).

17. PCI SSC (2022) *Payment card industry data security standard v4.0*. PCI Security Standards Council. Available at: https://www.pcisecuritystandards.org/document_library/ (Accessed: 10 April 2026).

18. Proofpoint (2023) *State of the phish 2023*. Sunnyvale: Proofpoint Inc. Available at: https://www.proofpoint.com/us/resources/threat-reports/state-of-phish (Accessed: 12 April 2026).

19. Solove, D.J. and Schwartz, P.M. (2021) *Information privacy law*. 7th edn. New York: Wolters Kluwer.

20. Voigt, P. and von dem Bussche, A. (2017) *The EU general data protection regulation (GDPR): A practical guide*. Cham: Springer.

21. von Solms, R. and van Niekerk, J. (2013) 'From information security to cyber security', *Computers & Security*, 38, pp. 97–102. https://doi.org/10.1016/j.cose.2013.04.004 (Accessed: 12 April 2026).